

SmartFuzz

Security Assessment Report

Target: http://testfire.net/

Scan Date: 2026-05-18 14:02:04 UTC

Scan ID: 6f181867-a5f3-425a-b1a2-744095c3f899

1. Executive Summary

Target URL	http://testfire.net/
Scan Date	2026-05-18 14:02:04 UTC
Vuln Classes	SQLi, XSS, RCE, SSRF, Command Injection, Auth Bypass, IDOR
Overall Risk	Critical

10	2	6	2	0	1	132
Total	Critical	High	Medium	Low	Forms	Payloads

2. Findings

Summary

#	Vulnerability	Parameter	Severity	Response Snippet
1	SSRF	content	Critical	<!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC " -//W3C//DTD XHTML 1.0 Transitional//EN" " http://www.w3.org/TR/xhtml1/DTD/x...
2	SSRF	content	Critical	<!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC " -//W3C//DTD XHTML 1.0 Transitional//EN" " http://www.w3.org/TR/xhtml1/DTD/x...
3	IDOR	content	High	<!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC " -//W3C//DTD XHTML 1.0 Transitional//EN" " http://www.w3.org/TR/xhtml1/DTD/x...
4	IDOR	content	High	<!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC " -//W3C//DTD XHTML 1.0 Transitional//EN" " http://www.w3.org/TR/xhtml1/DTD/x...
5	IDOR	content	High	</title> <meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1" /> <link href="/style.css" rel="s...
6	IDOR	content	High	<!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC " -//W3C//DTD XHTML 1.0 Transitional//EN" " http://www.w3.org/TR/xhtml1/DTD/x...
7	IDOR	content	High	<!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC " -//W3C//DTD XHTML 1.0 Transitional//EN" " http://www.w3.org/TR/xhtml1/DTD/x...
8	IDOR	content	High	<!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC " -//W3C//DTD XHTML 1.0 Transitional//EN" " http://www.w3.org/TR/xhtml1/DTD/x...
9	XSS	content	Medium	<!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC " -//W3C//DTD XHTML 1.0 Transitional//EN" " http://www.w3.org/TR/xhtml1/DTD/x...
10	XSS	content	Medium	<!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC " -//W3C//DTD XHTML 1.0 Transitional//EN" " http://www.w3.org/TR/xhtml1/DTD/x...

Detailed Findings

#1 SSRF — content

Critical

URL http://testfire.net/index.jsp?content=http%3A%2F%2F169.254.169.254%2Flatest%2Fmeta-data%2F

Status 200

Resp Time 0.297s

Timestamp 2026-05-18 14:01:32

Payload http://169.254.169.254/latest/meta-data/

Evidence <!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"> <html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" > <head> <title>Altoro Mutual</title> <meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1" /> <link href="/style.css" rel="stylesheet

Fix 1. Whitelist allowed destination domains/IPs and reject everything else. 2. Block requests to 169.254.0.0/16 (AWS metadata), 10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16. 3. Disable HTTP redirects, or re-validate the final destination URL after each redirect. 4. Use a dedicated egress proxy that enforces the allowlist. 5. Avoid accepting user-supplied URLs entirely where possible. 6. Reference: OWASP Top 10 A10:2021 — SSRF

#2 SSRF — content

Critical

URL http://testfire.net/index.jsp?content=http%3A%2F%2F169.254.169.254%2Flatest%2Fuser-data%2F

Status 200

Resp Time 0.281s

Timestamp 2026-05-18 14:01:32

Payload http://169.254.169.254/latest/user-data/

Evidence <!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"> <html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" > <head> <title>Altoro Mutual</title> <meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1" /> <link href="/style.css" rel="stylesheet

Fix 1. Whitelist allowed destination domains/IPs and reject everything else. 2. Block requests to 169.254.0.0/16 (AWS metadata), 10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16. 3. Disable HTTP redirects, or re-validate the final destination URL after each redirect. 4. Use a dedicated egress proxy that enforces the allowlist. 5. Avoid accepting user-supplied URLs entirely where possible. 6. Reference: OWASP Top 10 A10:2021 — SSRF

#3 IDOR — content

High

URL http://testfire.net/index.jsp?content=0

Status 200

Resp Time 0.25s

Timestamp 2026-05-18 14:01:58

Payload 0

Evidence <!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"> <html xmlns="http://www.w3.org/1999/xhtml

Fix 1. Implement access control checks for every object reference. 2. Use indirect object references (e.g., random UUIDs) instead of predictable sequential integers. 3. Verify that the currently authenticated user is authorised to access the requested resource ID. 4. Reference: OWASP Top 10 A01:2021 — Broken Access Control

#4 IDOR — content

High

URL http://testfire.net/index.jsp?content=1

Status 200

Resp Time 0.25s

Timestamp 2026-05-18 14:01:58

Payload 1

Evidence <!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"> <html xmlns="http://www.w3.org/1999/xhtml

Fix 1. Implement access control checks for every object reference. 2. Use indirect object references (e.g., random UUIDs) instead of predictable sequential integers. 3. Verify that the currently authenticated user is authorised to access the requested resource ID. 4. Reference: OWASP Top 10 A01:2021 — Broken Access Control

#5 IDOR — content

High

URL http://testfire.net/index.jsp?content=-1

Status 200

Resp Time 0.266s

Timestamp 2026-05-18 14:01:58

Payload -1

Evidence </title> <meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1" /> <link href="/style.css" rel="stylesheet" type="text/css" /> </head> <body style="margin-top:5px;"> <div id=

Fix 1. Implement access control checks for every object reference. 2. Use indirect object references (e.g., random UUIDs) instead of predictable sequential integers. 3. Verify that the currently authenticated user is authorised to access the requested resource ID. 4. Reference: OWASP Top 10 A01:2021 — Broken Access Control

#6 IDOR — content

High

URL http://testfire.net/index.jsp?content=9999

Status 200

Resp Time 0.281s

Timestamp 2026-05-18 14:01:58

Payload 9999

Evidence <!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"> <html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" > <head> <title>Altoro Mutual</title> <meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1" /> <link href="/style.css" rel="stylesheet

Fix 1. Implement access control checks for every object reference. 2. Use indirect object references (e.g., random UUIDs) instead of predictable sequential integers. 3. Verify that the currently authenticated user is authorised to access the requested resource ID. 4. Reference: OWASP Top 10 A01:2021 — Broken Access Control

#7 IDOR — content

High

URL http://testfire.net/index.jsp?content=admin

Status 200

Resp Time 0.234s

Timestamp 2026-05-18 14:01:58

Payload admin

Evidence <!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"> <html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" > <head> <title>Altoro Mutual</title> <meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1" /> <link href="/style.css" rel="stylesheet

Fix 1. Implement access control checks for every object reference. 2. Use indirect object references (e.g., random UUIDs) instead of predictable sequential integers. 3. Verify that the currently authenticated user is authorised to access the requested resource ID. 4. Reference: OWASP Top 10 A01:2021 — Broken Access Control

#8 IDOR — content

High

URL http://testfire.net/index.jsp?content=test

Status 200

Resp Time 0.265s

Timestamp 2026-05-18 14:01:58

Payload test

Evidence <!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"> <html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" > <head> <title>Altoro Mutual</title> <meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1" /> <link href="/style.css" rel="stylesheet

Fix 1. Implement access control checks for every object reference. 2. Use indirect object references (e.g., random UUIDs) instead of predictable sequential integers. 3. Verify that the currently authenticated user is authorised to access the requested resource ID. 4. Reference: OWASP Top 10 A01:2021 — Broken Access Control

#9 XSS — content

Medium

URL http://testfire.net/index.jsp?content=%27%3Balert%28%27XSS%27%29%2F%2F

Status 200

Resp Time 0.25s

Timestamp 2026-05-18 14:01:14

Payload ';alert('XSS')//

Evidence <!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"> <html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" > <head> <title>Altoro Mutual</title> <meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1" /> <link href="/style.css" rel="stylesheet

Fix 1. HTML-encode all user-controlled output before rendering (use your framework's auto-escaping). 2. Implement a strict Content-Security-Policy (CSP) response header. 3. Set HttpOnly and Secure flags on all session cookies. 4. Validate and sanitize input on the server side — treat all input as untrusted. 5. Use modern frameworks (React, Vue, Angular) that escape output by default. 6. Reference: OWASP Top 10 A03:2021 — Injection

#10 XSS — content

Medium

URL	http://testfire.net/index.jsp?content=%3Cdetails+open+ontoggle%3Dalert%28%27XSS%27%29%3E
Status	200
Resp Time	0.25s
Timestamp	2026-05-18 14:01:14
Payload	<details open ontoggle=alert('XSS')>
Evidence	<!-- BEGIN HEADER --> <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"> <html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" > <head> <title>Altoro Mutual</title> <meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1" /> <link href="/style.css" rel="stylesheet
Fix	1. HTML-encode all user-controlled output before rendering (use your framework's auto-escaping). 2. Implement a strict Content-Security-Policy (CSP) response header. 3. Set HttpOnly and Secure flags on all session cookies. 4. Validate and sanitize input on the server side — treat all input as untrusted. 5. Use modern frameworks (React, Vue, Angular) that escape output by default. 6. Reference: OWASP Top 10 A03:2021 — Injection

3. Remediation Reference

SSRF

1. Whitelist allowed destination domains/IPs and reject everything else.
2. Block requests to 169.254.0.0/16 (AWS metadata), 10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16.
3. Disable HTTP redirects, or re-validate the final destination URL after each redirect.
4. Use a dedicated egress proxy that enforces the allowlist.
5. Avoid accepting user-supplied URLs entirely where possible.
6. Reference: OWASP Top 10 A10:2021 — SSRF

IDOR

1. Implement access control checks for every object reference.
2. Use indirect object references (e.g., random UUIDs) instead of predictable sequential integers.
3. Verify that the currently authenticated user is authorised to access the requested resource ID.
4. Reference: OWASP Top 10 A01:2021 — Broken Access Control

XSS

1. HTML-encode all user-controlled output before rendering (use your framework's auto-escaping).
2. Implement a strict Content-Security-Policy (CSP) response header.
3. Set HttpOnly and Secure flags on all session cookies.
4. Validate and sanitize input on the server side — treat all input as untrusted.
5. Use modern frameworks (React, Vue, Angular) that escape output by default.
6. Reference: OWASP Top 10 A03:2021 — Injection

4. Disclaimer

This report was generated automatically by SmartFuzz. Results should be reviewed and validated by a qualified security professional before acting upon them. False positives may be present. This tool is intended for use only against systems you own or have explicit written authorisation to test. Unauthorised testing is illegal and unethical.

Generated by SmartFuzz · 2026-05-18 14:02:04 UTC